

PROJET AIS

Document HLD

Diagrammes de séquence, périmètres de sécurité, matrice de flux et diagramme réseau

Infrastructure applicative sécurisée — 5 août 2026

Classification	Confidentiel — Usage interne
Version	260805
Statut	A valider

	Nom	Date
Rédaction	Thomas Michel	05/08/26
Validation	Xx	Xx

Version	Changement	Rédaction	Validation
260722	Rédaction initiale	Thomas Michel	Quentin Mallet
260728	Ajout du serveur de sauvegardes	Thomas Michel	Quentin Mallet
260805	Ajout TLS applicatif , Passage des sauvegardes en mode push, suppression de FL-08 et remappage de FL-09, ajout de fail2ban	Thomas Michel	

Table des matières

Table des matières 2

1. Historique des changements..... 2

2. Introduction 3

3. Diagrammes de séquence 4

 3.1 Interaction utilisateur (consultation et dépôt d'un message) 4

 3.2 Interaction administrateur (administration générale des serveurs) 4

4. Diagramme des périmètres de sécurité..... 6

5. Matrice de flux 7

6. Diagramme réseau 9

1. Historique des changements

260728 : Ajout de la mention du serveur de sauvegarde Borg dans la partie 2 (Introduction) et figure 2, modification des figures 3 & 4 en conséquence et ajout des flux FL-07, FL-08 et FL-09.

260805 : Ajout du TLS applicatif sur SRV-1. Port 80 redirige désormais vers 443. Modification de la figure 1 (flux HTTPS) et de la matrice de flux (FL-01 mis à jour, FL-01bis ajouté). Passage des sauvegardes BORG en mode push. Suppression du flux FL-08 et remappage de l'ancien FL-09 en FL-08. Ajout de fail2ban comme mesure de sécurisation complémentaire sur le flux FL-04. Mise à jour de la section 4 et de la figure 4 en conséquence.

2. Introduction

Ce document présente la conception de haut niveau (HLD) de l'infrastructure hébergeant l'application interne « mur de messages ». L'architecture repose sur trois serveurs internes dédiés, un bastion d'administration, une machine de supervision et une machine de sauvegarde :

- SRV-1 : serveur applicatif, héberge l'application web exposée aux utilisateurs par un serveur nginx (TLS) comme proxy vers l'application flask.
- SRV-2 : serveur de base de données, héberge PostgreSQL et n'est jamais exposé directement à l'extérieur.
- Bastion : point de passage unique et journalisé pour toute administration système.
- Backup : serveur de sauvegarde (BORG), connecté uniquement au pare-feu ; reçoit en mode push la sauvegarde initiée par SRV-2 et s'administre via le bastion, comme les autres serveurs internes.
- SIEM : centralise les journaux des quatre machines précédentes et du pare-feu, pour la corrélation et la détection d'incidents.

L'accès depuis l'extérieur est filtré par un pare-feu périmétrique (PfSense), qui n'autorise que les flux strictement nécessaires. Ce pare-feu agit également comme routeur entre tous les segments internes : aucun flux, y compris entre le serveur applicatif et la base de données, ne transite directement d'un segment à l'autre sans passer par lui — c'est le principe de sécurité en profondeur retenu pour cette architecture. Chaque serveur applique en complément son propre durcissement iptables.

⚠ Principe clé — Aucun flux inter-segment ne contourne PfSense, y compris entre SRV-1 et SRV-2.

3. Diagrammes de séquence

3.1 Interaction utilisateur (consultation et dépôt d'un message)

Ce diagramme illustre le parcours d'un utilisateur consultant le mur de messages (<http://lechatdethomas.local>), puis y déposant un nouveau message. Le pare-feu PfSense n'autorise que les ports 80/tcp et 443/tcp vers SRV-1 pour le proxy interne vers le port 5000. Point important : SRV-1 ne dialogue jamais directement avec SRV-2 — chaque requête SQL est relayée par PfSense, qui applique sa propre règle de filtrage en plus de celle de SRV-2.

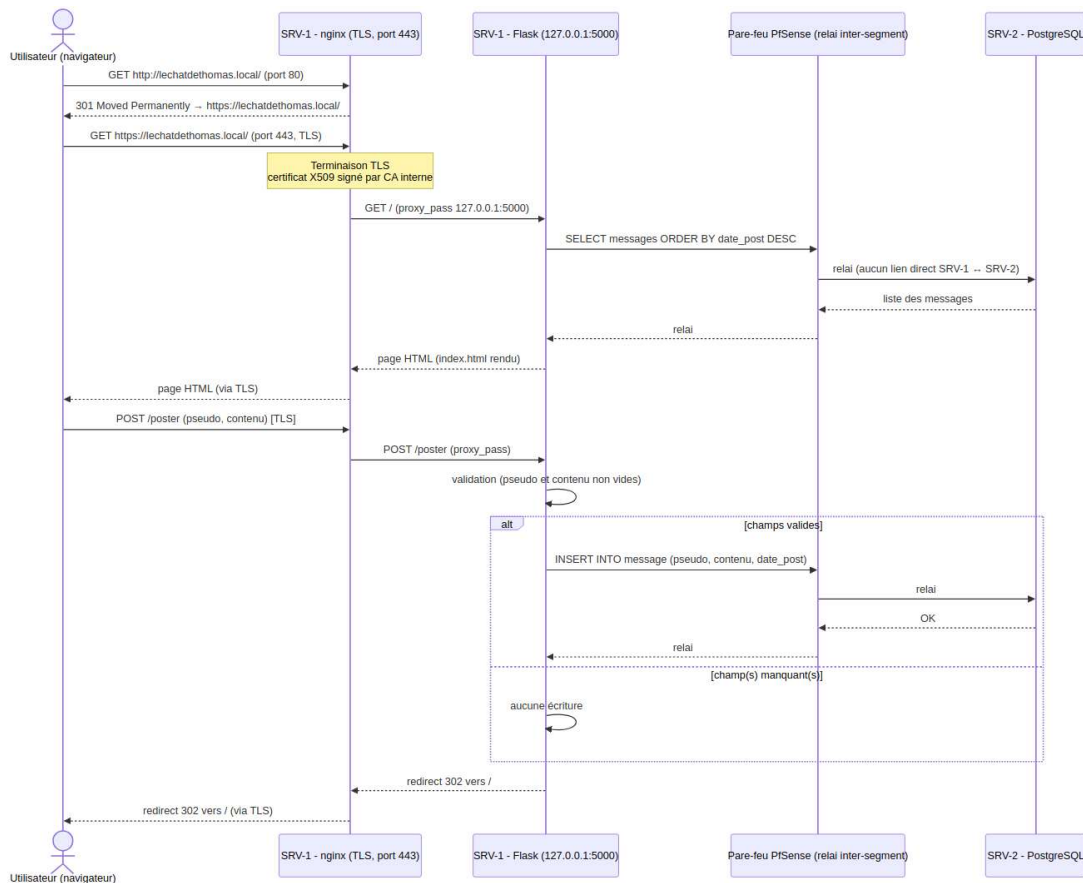


Figure 1 — Diagramme de séquence : interaction utilisateur

3.2 Interaction administrateur (administration générale des serveurs)

Ce diagramme illustre une session d'administration type : l'administrateur ne se connecte jamais directement à un serveur interne. Il passe d'abord par le pare-feu périmétrique (SSH sur le port 2222 — un port non standard qui réduit le bruit des scans automatisés mais n'est pas en soi une mesure de sécurité) puis par le bastion, qui journalise la session, avant de rebondir vers le serveur cible (SRV-1, SRV-2 ou Backup) pour y effectuer des opérations courantes — consultation des journaux, vérification de l'état des services, actions correctives — et non la seule mise en route d'une application.

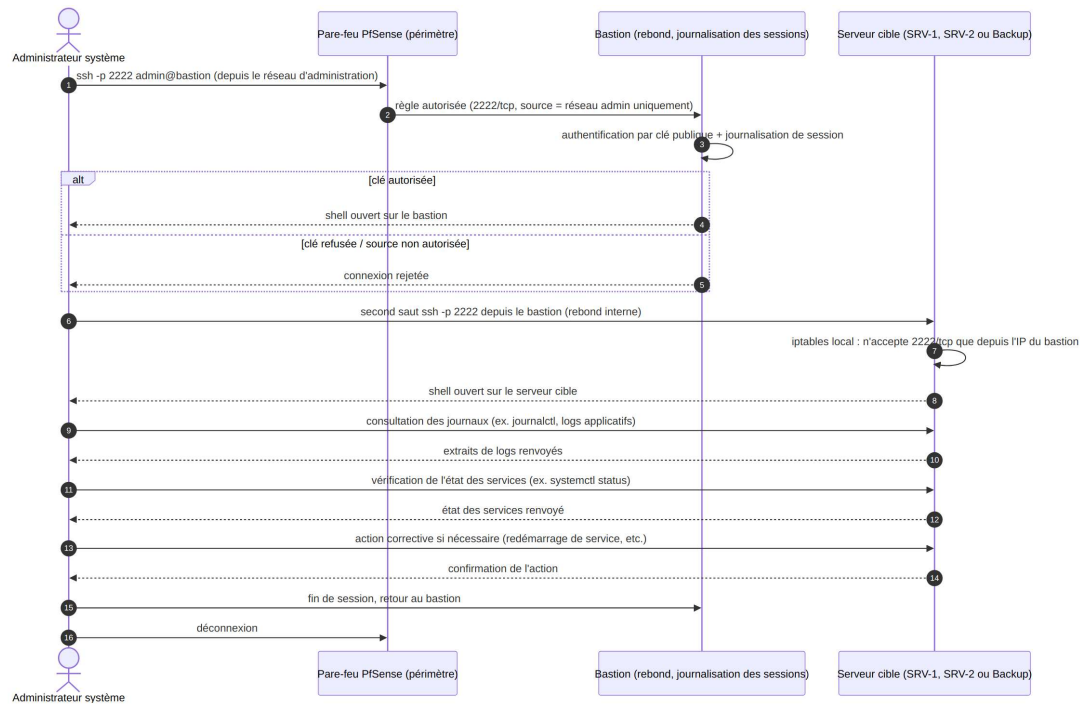


Figure 2 — Diagramme de séquence : interaction administrateur

4. Diagramme des périmètres de sécurité

Le schéma ci-dessous découpe l'infrastructure en zones de confiance croissant, de la zone publique (Internet, non fiable) jusqu'aux zones internes de données et de supervision. Chaque frontière de zone correspond à un point où une mesure de sécurisation est appliquée avant de laisser passer un flux vers la zone suivante. Le pare-feu PfSense assure le filtrage réseau au niveau périmétrique et relaie systématiquement tout flux inter-zone, y compris entre SRV-1 et SRV-2 ; les règles iptables locales à chaque serveur assurent une seconde couche de filtrage indépendante (défense en profondeur).

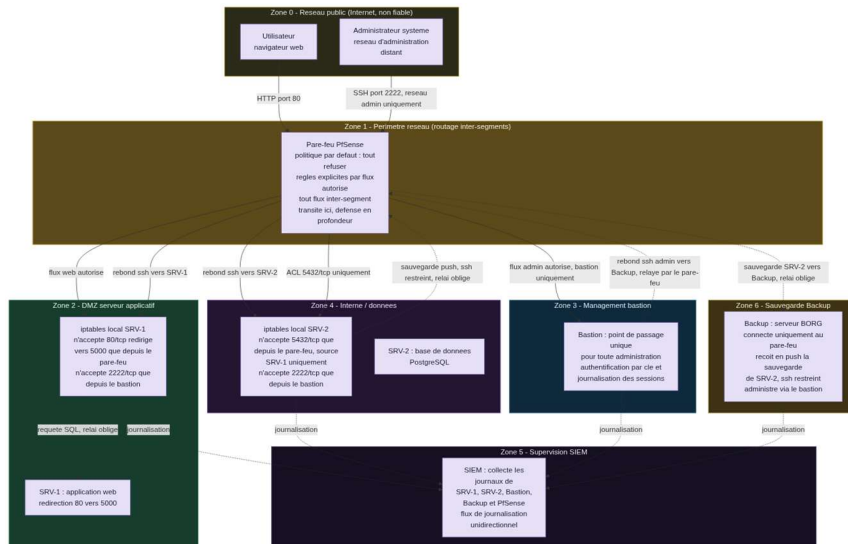


Figure 3 — Périmètres de sécurité de l'infrastructure

Légende des zones :

- Zone 0 — Réseau public (Internet, non fiable)
- Zone 1 — Périmètre réseau (pare-feu PfSense, routage inter-segments)
- Zone 2 — DMZ (serveur applicatif SRV-1 avec terminaison TLS)
- Zone 3 — Management (bastion)
- Zone 4 — Interne / données (SRV-2)
- Zone 5 — Supervision (SIEM)
- Zone 6 — Sauvegarde (Backup)

Une cinquième zone est dédiée à la supervision (SIEM) : SRV-1, SRV-2, le bastion et PfSense lui envoient chacun leurs journaux, dans un flux à sens unique — le SIEM ne peut initier aucune connexion vers les machines supervisées.

Une sixième zone est dédiée à la sauvegarde (Backup) : ce serveur BORG n'est connecté qu'au pare-feu, jamais directement à SRV-1 ou SRV-2. C'est désormais SRV-2 qui initie la sauvegarde (mode push) via une connexion SSH restreinte relayée par PfSense ; Backup s'administre depuis le bastion comme les autres serveurs internes et envoie également ses journaux au SIEM.

⚠ Principe clé — Le SIEM ne peut initier aucune connexion vers les machines supervisées : flux de journalisation strictement entrant.

5. Matrice de flux

Pour chaque flux réseau identifié dans l'architecture, le tableau suivant détaille le chemin emprunté et les mesures de sécurisation mises en place, aux niveaux périmétrique (PfSense) et local (iptables sur chaque serveur). Chaque flux est identifié par un code (FL-xx) pour faciliter son référencement dans d'autres documents (audits, tickets, revues de sécurité).

ID	Flux	Protocole / Port	Chemin (source → destination)	Mesures de sécurisation
FL-01	Accès web utilisateur	443/tcp	Internet → PfSense (443/tcp) → SRV-1 (nginx → proxy 127.0.0.1:5000)	PfSense pass direct vers SRV-1:443 ; SRV-1 (nginx) reçoit le TLS et proxy en interne vers 127.0.0.1:5000 Validation applicative des champs avant écriture ; accès public assumé.
FL-01bis	Redirection HTTP vers HTTPS	80/tcp	Internet → PfSense (80/tcp) → SRV-1 (nginx, redirect 301 vers 443)	PfSense autorise 80/tcp vers SRV-1 uniquement pour le redirect ; nginx ne sert aucun contenu applicatif sur ce port, renvoie 301 systématiquement vers https://. Certificat X509 signé par CA interne dédiée (séparée de la CA SSH), SAN incluant IP et FQDN, validité 397 jours.
FL-02	Accès administrateur au bastion	2222/tcp	Réseau d'administration → PfSense (2222/tcp) → Bastion	PfSense : port 2222 ouvert uniquement depuis le réseau admin, vers le bastion. Le changement de port réduit le bruit des scans automatisés mais n'est pas une mesure de sécurité en soi (simple obscurcissement). La protection réelle repose sur l'authentification par clé publique et la journalisation des sessions. Aucun serveur interne joignable directement depuis l'extérieur.
FL-03	Rebond bastion → SRV-1 / SRV-2	2222/tcp	Bastion → PfSense (relai) → SRV-1 ou SRV-2	Rebond systématiquement relayé par PfSense (aucun lien direct entre segments). iptables local : n'accepte 2222/tcp que depuis l'IP du bastion. Usage : logs, état des services, actions correctives.
FL-04	Flux applicatif SRV-1 → SRV-2	5432/tcp (PostgreSQL)	SRV-1 → PfSense (relai) → SRV-2	Toute requête SQL transite par PfSense : aucun lien réseau direct entre SRV-1 et SRV-2 (sécurité en profondeur). ACL PfSense + iptables SRV-2 : n'acceptent 5432/tcp que depuis SRV-1. Identifiants applicatifs dédiés, non exposés dans le code. fail2ban actif sur SRV-2 : bannissement automatique des

ID	Flux	Protocole / Port	Chemin (source → destination)	Mesures de sécurisation
				sources après tentatives de connexion répétées ou invalides sur 5432/tcp.
FL-05	Politique de filtrage périmétrique (PfSense)	—	Toutes zones ↔ PfSense (règles inter-segments)	Deny-all par défaut sur toutes les interfaces ; aucun trafic inter-segment ne contourne le pare-feu. Seuls les flux explicitement listés dans cette matrice sont autorisés.
FL-06	Journalisation vers le SIEM	syslog	SRV-1, SRV-2, Bastion, PfSense → SIEM (segment Supervision)	Flux unidirectionnel : le SIEM ne peut initier aucune connexion vers les serveurs supervisés. Relayé par PfSense comme tout flux inter-segment ; ACL dédiée pour le seul port de journalisation. Centralise les journaux des 4 autres machines pour la corrélation et la détection d'incidents.
FL-07	Rebond bastion → Backup	2222/tcp	Bastion → PfSense (relai) → Backup (administration)	Rebond systématiquement relayé par PfSense, comme pour SRV-1 et SRV-2. iptables local : n'accepte 2222/tcp que depuis l'IP du bastion. Usage : logs, état des services, actions correctives sur le serveur de sauvegarde.
FL-08	Sauvegarde SRV-2 → Backup	2222/tcp	SRV-2 → PfSense (relai) → Backup (SSH restreint, BORG)	SRV-2 initie la connexion (mode push) ; relayée par PfSense comme tout flux inter-segment. iptables Backup : n'accepte 2222/tcp que depuis le bastion ou depuis SRV-2. Commande SSH restreinte (borg serve) : pas de shell interactif, périmètre limité au dépôt de sauvegarde. Backup n'est jamais connecté directement à SRV-1 ou SRV-2 : il n'est relié qu'au pare-feu.

